

Capstone Assignment: Threat & Risk Assessment

Assignment Type: Individual Capstone Project

Expected Length: 10 pages minimum

Submission Format: Professional Assessment Report

Please follow the TRA guideline provided as a supplemental document to complete your professional report. All mock screenshots/evidence is located in Appendix A below.

Organizational Context and Assumed Role

Organization Overview

This assessment is conducted for a mid-sized enterprise operating within a regulated industry sector (e.g., financial services) that leverages Amazon Web Services (AWS) as its primary cloud infrastructure provider. The organization hosts production workloads in AWS, including sensitive financial reporting data stored in S3 buckets and application workloads deployed via CI/CD pipelines.

Cloud identity and access management (IAM) is central to business operations. IAM roles support automated build pipelines, internal application services, and administrative functions. Due to rapid cloud adoption and DevOps-driven deployment velocity, identity sprawl and privilege management have evolved organically, increasing the risk of excessive permissions and misconfigurations.

The organization is subject to regulatory and contractual obligations requiring protection of sensitive financial and operational data. A compromise of privileged IAM roles or unauthorized access to production S3 data could result in:

- Regulatory penalties
- Contractual breaches
- Financial loss
- Reputational damage

- Operational disruption

The organization operates in a cloud-first, DevOps-enabled environment where automation roles (e.g., CI/CD build roles) often hold broad permissions to maintain deployment agility. This creates a tension between operational efficiency and least-privilege enforcement.

The current threat landscape includes:

- Credential compromise of cloud service roles
- Privilege escalation through misconfigured IAM policies
- Abuse of iam:PassRole and iam:AttachRolePolicy permissions
- Unauthorized access to sensitive S3 data
- Living-off-the-cloud techniques using valid accounts

Adversaries increasingly target cloud identity as the primary attack vector, bypassing traditional perimeter defenses. As a result, IAM misconfigurations represent a high-impact risk domain, especially when combined with insufficient monitoring and delayed response.

Assumed Role of the Analyst

The student assumes the role of a Cloud Security Analyst within the Security Operations Center (SOC) responsible for:

- Investigating high-severity SIEM alerts
- Correlating CloudTrail telemetry with IAM activity
- Mapping observed attacker behavior to MITRE ATT&CK
- Constructing a defensible incident narrative
- Conducting a formal Threat & Risk Assessment (TRA)
- Providing executive-level risk justification and mitigation recommendations

This role requires both technical analysis and executive reasoning. Findings must be defensible, evidence-based, and aligned to business risk—not solely technical misconfiguration.

1. Key Assignment Points/Learning Objectives

Upon completion of this capstone, students will be able to:

- Analyze the provided Appendix A artifacts
- Reconstruct the full attack chain and construct a chronological attacker narrative.
- Identify AWS IAM misconfigurations and privilege escalation paths.
- Map observed behavior/activity to MITRE ATT&CK techniques using correct IDs and names. (<https://attack.mitre.org/>)
- Correlate SIEM alerts and CloudTrail events using timestamps and principals.
- Prioritize and justify the highest-impact cloud identity risks (2) and provide mitigations in a professional report.

2. How to Interpret AWS Evidence

2.1 Reading the IAM Dashboard

Focus on:

- Number of users, roles, policies (identity sprawl risk).
- Users/roles attached to AdministratorAccess.
- Absence of MFA enforcement for privileged users.
- Lack of permission boundaries.
- Consider blast radius and least privilege violations.

Relevant MITRE Techniques:

- T1087.004 — Account Discovery: Cloud Account (Discovery).
- T1069.003 — Permission Groups Discovery: Cloud Groups (Discovery).

Callouts - What to Notice/Include in Assessment:

- Total number of users, roles, and policies, and the name for this risk.
- Description of highly privileged policies.
- Explanation of least privilege not being enforced.

How to Use This:

Reference when identifying critical assets, privileged principals, and systemic IAM risk (if considered as the top 1 or 2 risks) in your Threat & Risk Assessment.

2.2 Interpreting IAM Policy JSON

Translate permissions into attacker capability.

High-risk permissions:

- iam:PassRole
- iam:AttachRolePolicy
- iam:PutRolePolicy
- iam:CreateAccessKey

Look for:

- Resource: "*"
- Missing Condition blocks
- No MFA enforcement

Relevant MITRE Techniques:

- T1098 — Account Manipulation (Persistence / Privilege Escalation).
- T1098.003 — Account Manipulation: Additional Cloud Credentials.
- T1548.005 — Abuse Elevation Control Mechanism: Temporary Elevated Cloud Access.

Callouts – What to Notice/Include in Assessment:

- Alert severity
- IAM API calls
- Time of activity

How to Use This:

Use the alert to analyze the detection logic, map to MITRE ATT&CK, and determining incident severity.

2.3 Correlating CloudTrail and SIEM (Figure 3 — SIEM Alert — IAM Enumeration, Figure 4 — CloudTrail — S3 Object Access, CloudTrail Event Snippet & SIEM Alert Log Snippet)

CloudTrail = raw API events.

SIEM = detection logic + alerting.

Correlate:

- Principal ARN
- Event time
- API calls

Discovery - Escalation - Data Access progression.

Relevant MITRE Techniques:

- T1530 — Data from Cloud Storage (Collection).
- T1078.004 — Valid Accounts: Cloud Accounts (Initial Access / Persistence).
- T1087.004 — Account Discovery: Cloud Account.

Note: T1046 — Network Service Discovery should only be mapped if network-level discovery activity (e.g., port scanning) is observed in telemetry.

Callouts – What to Notice/Include in Assessment:

- Bucket name
- API call roll/permissions
- Temporal proximity to earlier IAM alerts

How to Use This:

Reference the artifacts when explaining data access impact, containment actions, and post-incident analysis.

3. Required Attacker Narrative

You must construct a chronological SOC-style incident narrative including:

1. IAM Enumeration (Discovery).
2. Identification of Escalation Path.
3. Privilege Escalation.
4. S3 Data Access.

Each stage must reference:

- Specific API calls.
- Timestamps.

- Appendix evidence figures.
- Correct MITRE technique IDs with names.

4. Risk Prioritization Requirement

Identify and justify the top TWO highest-impact risks.

For each prioritized risk:

- Likelihood (ease of exploitation).
- Impact (sensitive data exposure).
- Business consequence (financial, regulatory, reputational).

Avoid listing every minor issue. Focus on material risk.

5. Evidence Citation Requirements

Evidence Citation Template (Format):

Appendix A — Figure X; EventTime: 2026-02-12T02:14:00Z; API: ListUsers; Principal: CICD-Build-Role.

Your document should include the following:

- Mock screenshots (provided)
- Tables summarizing permissions or alerts
- **Optional, but nice to have:** diagrams illustrating attack paths

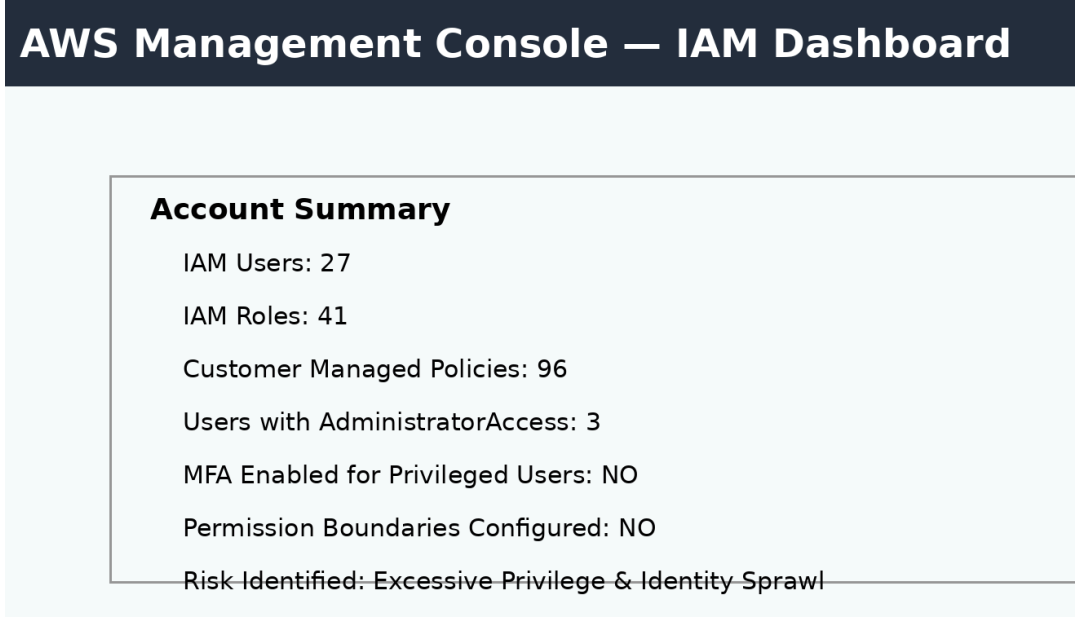
Guidelines:

- Evidence must be clearly labeled and referenced in the main report.
- Appendices will be assessed for clarity and relevance.

All claims included in the assessment report must reference specific appendix evidence.

Appendix A: Canonical Evidence Artifacts (Analyze These)

Figure 1 — IAM Dashboard Overview



This artifact must be referenced in your analysis.

Figure 2 — IAM Policy Review

AWS Management Console — IAM > Policies > DevOps-ExtendedAccess

Policy Summary

Policy Name: DevOps-ExtendedAccess
Policy Type: Customer Managed
Attached Entities: 2 Roles (including CICD-Build-Role)
Default Version: v3
Permissions Boundary: Not Set

Policy Document (JSON)

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Action": [
        "iam:PassRole",
        "iam:AttachRolePolicy",
        "iam:PutRolePolicy"
      ],
      "Resource": "*"
    }
  ]
}
```

Condition Block: NONE
Escalation Risk: Role can grant elevated privileges

This artifact must be referenced in your analysis.

Figure 3 — SIEM Alert — IAM Enumeration

SIEM Alert — IAM Enumeration Detected

Severity: HIGH

Principal: arn:aws:iam::123456789012:role/CICD-Build-Role

First Seen: 2026-02-12T02:14:03Z

Last Seen: 2026-02-12T02:18:44Z

API Calls: ListUsers, GetPolicy, ListRoles

MITRE: TA0007 — Discovery

Technique: T1087.004 — Account Discovery: Cloud Account

This artifact must be referenced in your analysis.

Figure 4 — CloudTrail — S3 Object Access

CloudTrail Event — S3 Object Access

Event Time: 2026-02-12T02:20:15Z

Event Name: GetObject

Bucket: prod-finance-reports

User ARN: arn:aws:iam::123456789012:role/CICD-Build-Role

Source IP: 52.14.22.199

Result: Success

Occurred 6 minutes after IAM enumeration alert

This artifact must be referenced in your analysis.

Supporting Raw JSON Artifacts

IAM Policy Snippet

```
{  
  "Effect": "Allow",  
  "Action": ["iam:PassRole", "iam:AttachRolePolicy"],  
  "Resource": "*"   
}
```

CloudTrail Event Snippet

```
{  
  "eventTime": "2026-02-12T02:20:15Z",  
  "eventName": "GetObject",  
  "userIdentity": {"arn": "arn:aws:iam::123456789012:role/CICD-Build-Role"},  
  "requestParameters": {"bucketName": "prod-finance-reports"}  
}
```

SIEM Alert Log Snippet

```
{  
  "severity": "HIGH",  
  "principal": "CICD-Build-Role",  
  "apiCalls": ["ListUsers", "GetPolicy", "ListRoles"],  
  "firstSeen": "2026-02-12T02:14:03Z"  
}
```

Grading Rubric

Category	Criteria	Excellent	Good	Satisfactory	Needs Improvement	Weight
Reconnaissance Analysis	Attacker perspective, clarity, attack paths that could be used for exploit.	Clear, logical, realistic attacker workflow.	Good coverage, minor omissions	Basic enumeration/explanation only	Unrealistic or poorly explained.	20%
Penetration Test (Simulated)	Structure, simulated findings/attack vectors/potential exploits, professionalism.	Industry quality report with strong findings	Well-structured with minor issues	Adequate but lacks polish	Poor structure or missing sections	30%
Incident Response & SIEM	Alert analysis, response actions	Strong analysis aligned to best practices	Mostly correct with small gaps	Basic response steps	Incomplete or incorrect response	20%
Threat & Risk Assessment	Asset identification, threat analysis, risk justification, mitigations	Comprehensive, well-justified, realistic risk analysis and mitigations.	Mostly complete with minor gaps.	Basic analysis, limited depth.	Missing key risks/mitigations or unclear reasoning.	30%